

技术文档 · TECHNICAL DOCUMENT

Haven-Store

二手商品交易平台的 AI 辅助开发技术文档（v1.1 润色版）：系统阐述本次全方位升级的意图控制策略（如何设计上下文与 Prompt）、架构设计（AI 生成代码采用的架构与约束手段）与可复现性论证。优化清单共 56 项、落地 52 项，交付 336 项冒烟断言与 66 项单元测试全绿的可复现基线。

版本 1.1 · 2026 年 10 月

目录

本文档面向两类读者：项目的评审者与后续接手开发的工程师。全文围绕 2026 年 10 月完成的一次系统性升级展开，重点回答三个问题：AI 辅助开发中如何控制生成意图（第二章）、升级后的代码采用什么架构以及如何约束（第三章）、成果如何被第三方复现与验证（第四章）。

章节	内容
第一章 项目概述	项目背景、技术栈、升级范围与升级前后对比
第二章 意图控制策略	协作流程、上下文设计、Prompt 设计原则与模式、防跑偏机制
第三章 架构设计	总体架构、后端分层、数据模型、契约层、鉴权链路、并发一致性、前端架构与约束手段
第四章 可复现性论证	复现性声明、依赖锁定、配置即代码、行为断言、非确定性分析与复现演练记录
第五章 总结与展望	成效数据与后续路线
附录 A 环境变量表	全部可注入配置项
附录 B 接口清单摘要	按模块归纳的 REST 端点
附录 C 常见问题	复现时的典型故障与处置

第一章 项目概述

1.1 项目简介与升级范围

Haven-Store 是一个基于 Spring Boot 与 Vue 3 的全栈二手商品交易平台，提供商品发布、附近商品检索、AI 估价、商品评价、收藏与购物车、下单支付（模拟支付）、私信与商品咨询、系统消息、管理后台等能力。项目代码仓库为 github.com/istilljump/Haven-Store。

「待补充：项目立项背景（课程设计、竞赛或产品原型）与目标用户规模。」

2026 年 10 月，项目完成了一次系统性升级。升级采用「先盘点、再审查、后实施」的 AI 辅助协作方式：先由两个只读探索代理对前后端做全量扫描，产出结构化的优化清单；清单经人工逐条审查后，分五个阶段实施；最终以单元测试 66 项与冒烟测试 336 项断言全部通过作为完成标志。

优化清单共 56 项，按 A~F 六组编号（A 必修缺陷 10 项、B 普通用户端 12 项、C 管理员端 9 项、D 前端体验 10 项、E 安全与健壮性 10 项、F 工程化 5 项）。本轮落地 52 项；其余 4 项按审查约定延后或调整：B12（浏览历史）、C9（操作日志）、E10（手机号全面脱敏）为可选项未实施，F3（统一分页 VO）因涉及全部列表接口的契约变更，评估后暂缓。

1.2 技术栈

层	技术选型	版本	说明
后端框架	Spring Boot	2.7.12	内嵌 Tomcat，统一上下文路径 /api

层	技术选型	版本	说明
ORM	MyBatis-Plus	3.5.3.1	分页插件 maxLimit=200; 查询统一使用 LambdaQueryWrapper 参数化构建
鉴权	JWT (HS256)	0.11.5	拦截器级登录态解析与账号状态校验
存储	MySQL 8 / Redis 7	—	业务数据; 登录缓存、登录锁定计数、分类缓存
接口文档	Knife4j (Swagger2)	4.1.0	开发环境开启, 生产环境关闭
前端框架	Vue 3 + Vite 5	^3.4	Composition API, 路由按模块分包并懒加载
UI 与状态	Element Plus / Pinia	^2.4 / ^2.1	中文语言包; Pinia 作为唯一全局状态中心
可视化	ECharts	^5.5	管理看板趋势图与分类分布图, 构建时独立分包

1.3 交付成果概览

56 项清单条目按六组归类, 各组交付情况如下:

分组	数量	代表性成果
A 必修缺陷	10 项	注册功能打通; 系统消息伪造漏洞摘除; 禁用账号 Token 立即失效; 分类排序未保存、设置页无法保存等未生效功能修复
B 普通用户端	12 项	首页重构、通知中心、订单详情页、我的发布管理页、AI 估价入口、附近商品、评价与订单关联、商品举报、搜索排序增强、订单超时自动取消
C 管理员端	9 项	订单管理 (含导出)、评论管理、举报处理台、用户编辑与重置密码、ECharts 数据看板、系统设置落库并真实生效、群发消息批次化
D 前端体验	10 项	共享组件 (ApplImage/ProductCard)、全局请求进度条、favicon、移动端适配收口、死代码清理
E 安全与健壮性	10 项	登录防爆破、上传魔数校验、事务补齐、Redis 序列化白名单、CSV 公式注入防护、条件更新消除并发重复推进
F 工程化	5 项	分类缓存、评分改 SQL 聚合、ESLint/Prettier 配置补齐、依赖显式声明、测试回归 (F3 统一分页 VO 暂缓)

1.4 升级前后对比

维度	升级前	升级后
安全	/message/send 端点任何登录用户可伪造系统公告; 禁用账号的 Token 在有效期内仍可交易	漏洞端点移除; 拦截器逐请求校验账号状态, 禁用即时失效; 登录锁定与密码策略生效
用户端	注册页未实现提交逻辑; 首页无商品内容; 无通知中心、订单详情、我的发布页	注册-发布-搜索-附近-估价-下单-支付-评价-举报-私信-通知全链路可用
管理端	无法查看订单与评论; 无举报处理; 系统设置保存后对后端行为无影响	订单/评论/举报/用户管理/看板图表齐备; 设置落库并真实约束业务

维度	升级前	升级后
测试	冒烟测试 26 项断言失败；单元测试 66 项中 63 项从未通过	冒烟测试 336 项断言全部通过；单元测试 66 项全部通过
工程	无 ESLint 配置；图标库为未声明的幽灵依赖；存在多个死代码文件	Lint 配置补齐；依赖显式声明；死代码清零；ECharts 独立分包

第二章 意图控制策略

AI 辅助开发的主要风险不是「写不出代码」，而是「写出的代码与意图偏离」：擅自扩大范围、引入未经审查的方案、编造不存在的接口。本章记录升级过程中控制这类风险的三个手段：协作流程设计（2.1）、上下文工程（2.2）与 Prompt 约束（2.3 ~ 2.4），以及发生偏离后的纠偏机制（2.5）。

2.1 总体流程：先对齐、再实施、逐步验证

「生成代码」在整条流水线中占时最短；多数工作量花在生成之前的事实对齐与生成之后的验证上：

- ① 全量盘点：两个只读探索代理并行扫描前后端，产出结构化现状报告
 - ② 清单化：将盘点结论整理为 56 项优化条目，按 A~F 分组编号并标注优先级
 - ③ 人工审查：逐条确认范围，可选项显式二选一（如 C8 商品审核流选择「轻量方案」）
 - ④ 排序实施：按 A → E → B → C → D/F 的顺序建立贯穿全程的任务清单
 - ⑤ 分阶段验证：每个阶段以「编译零错误 + 冒烟测试不出现新失败」作为完成定义
 - ⑥ 全量回归：单元测试 66 项 + 冒烟测试 336 项 + 前端构建

这一流程的核心作用是：把一句「全方位升级」转化为 56 项带编号、可追溯、可验证的具体条目；任何一处代码改动都能对应回某个清单编号，AI 不存在绕过清单自由发挥的空间。

2.2 上下文设计

2.2.1 结构化盘点先行

在编写任何升级代码之前，两个只读探索代理（AI 编码工具中承担调研任务的子代理，只读不写）分别对后端约 50 个接口与前端 20 个视图做全量扫描，产出包含接口清单、各域业务现状、安全与健壮性问题（附文件与行号）、配置审查、缺失功能对照在内的结构化报告。这份报告是最重要的上下文投入：后续每次代码生成都在同一份事实基础上进行。其直接收益是避免了凭印象编码——例如盘点发现前端 user.js 中封装了 10 个后端并不存在的接口，这类问题靠逐页浏览很难被发现。

2.2.2 上下文分级加载

并非所有信息都需要常驻上下文。本项目按四个层级管理，以控制上下文窗口的信噪比：

层级	内容	加载时机	示例
需求级	经审查的 56 项清单与裁剪决策	全程常驻	C8 选择轻量方案；本轮不接入 WebSocket

层级	内容	加载时机	示例
架构级	技术栈、分层约定、统一返回结构、鉴权链路	进入某模块前	Result{code,msg,data} 契约、按域分包模式
局部级	待修改文件全文及其关联文件	每次编辑前	修改 ProductServiceImpl 前先通读全部约 900 行
事实级	数据库 Schema、枚举取值、接口路径	涉及契约时	商品状态仅 1/2/3，订单状态仅 1~4

2.2.3 任务清单作为持久锚点

实施全程维护一份与清单编号对应的任务清单，完成一项即勾选一项。它的作用超出进度管理：当会话上下文因超长被摘要压缩时，任务清单是唯一跨压缩边界保留的总纲，保证压缩后的生成仍然锚定在已审查的范围内。

2.3 Prompt 设计原则

原则	做法	反例
验收标准前置	每阶段开始前先声明「完成的定义」：编译零错误、冒烟测试无新增失败	先写代码，再考虑如何验证
约束优先于指令	显式列出本轮不做的事项及理由：真实支付网关、WebSocket 推送、Spring Boot 3 迁移、暗色模式	只描述要做什么，边界由模型自行决定
对齐既有契约	新代码的字段名、枚举值、状态码必须引用既有常量（OrderStatusEnum、ProductStatusEnum、ResultCodeEnum），禁止魔法值	前后端各自维护一套硬编码状态码
决策显式化	可选项要求「二选一并说明理由」，结论回写清单与文档	在多个方案之间默认折中，不留决策记录
小步交付	每个阶段结束给出可验证节点，而非一次性交付全部改动	全部完成后再统一验证

实践中收益最大的是「对齐既有契约」：本轮冒烟测试出现的 26 项失败，多数源于新旧代码契约错位（例如系统设置保存后 maxPrice=100 开始真实生效、发布超限商品被拒；密码策略 medium 拒绝纯数字演示口令）。这些失败恰恰证明约束已生效，正确的处置是让测试与文档对齐新契约，而不是放宽校验。

2.4 Prompt 模式示例

以下提炼自本次升级中复用率最高的三类 Prompt 骨架。共同特征：把事实、约束与验收标准写进指令，把方案选择权留给受约束的生成，并把「完成」定义为可机器判定的条件。

【模式一 · 盘点类】

- 对 <目录> 做 very thorough 的只读盘点。输出结构化报告，包含：
- 1) 接口清单（方法/路径/功能/权限）；
 - 2) 各域业务现状；
 - 3) 安全与健壮性问题清单（附文件:行号）；
 - 4) 配置审查；
 - 5) 对照完整平台列出缺失功能。报告将用于编写升级清单，不要给泛泛建议。

【模式二 · 实施类】

按清单编号 A2 修复：〈问题描述〉。约束：不引入新依赖；复用既有校验模式；修改前先读〈文件〉全文。完成定义：mvn compile 零错误，冒烟测试无新增失败。

【模式三 · 纠偏类】

冒烟测试出现 N 项失败。先逐项归因：属于「新契约生效导致旧断言过时」的，修正断言并在注释中写明契约依据；属于「代码缺陷」的，修复代码。

模式三的价值在于把「测试失败」从交付噪声转化为契约演进的驱动信号：本轮 26 项失败全部按此流程归因，多数归入「设置与密码策略真实生效导致旧断言过时」，其余为测试侧缺陷（如注册用例生成的手机号包含字母）并逐一修复。

2.5 防跑偏与纠偏机制

- 范围闸门：清单之外的功能想法一律记入「本轮不做」，不在实施过程中顺手实现；
- 验证闸门：五个阶段各自以编译与测试收口，第 2 阶段结束后即执行一次全量冒烟，而非全部完成后验证；
- 独立安全检查：仓库接入的独立安全工具（Mimosa）在源码写入与提交前做实时扫描，两次拦截冒烟测试中的硬编码口令写法，迫使其改为环境变量常量（口令来自公开种子数据，属演示凭据）；
- 自省式重写：生成过程中若发现自己写出引用已删除字段的包装方法，立即停止追加、回读文件并整体重写该段，而不是叠加补丁；
- 对照取证：对「单测失败是否为本次升级引入」这类关键判断，用 git worktree 在未改动的基线提交上复跑同版本测试，取得对照证据后再下结论——实测证明 63 项失败在升级前即存在。

第三章 架构设计

本章先给出总体架构与数据模型（3.1 ~ 3.3），再按请求路径依次说明契约层、鉴权链路与并发控制（3.4 ~ 3.6），然后是前端架构（3.7），最后归纳对 AI 生成代码施加的约束手段（3.8），该节是本章的落脚点，也与第四章的可复现性论证衔接。

3.1 总体架构

系统为前后端分离结构：Vue 3 单页应用在开发期经 Vite 代理、生产期经 Nginx 访问 Spring Boot 单体服务；数据落在 MySQL 与 Redis。单体内部按业务域垂直切分模块，每个域内再做控制器/服务/持久化分层；鉴权、异常、缓存、字段自动填充、定时任务等横切能力收敛到独立的 config 与 task 包。

前端 Vue 3 SPA (views / components / store / router / api 封装)

| HTTP (axios 拦截器统一注入 Token、解包 Result、统一错误提示)



后端 Spring Boot 单体 (/api 上下文)

└─ 拦截器链: JwtInterceptor (登录态 + 账号状态) → AdminAuthInterceptor (角色校验)

└─ 业务域: user / product / order / cart / message / admin / report / category

└─ 横切层: config (缓存/序列化/CORS) · task (定时任务) · common (Result/异常/常量)



存储 MySQL 8 (12 张表) + Redis 7 (用户缓存、登录锁定计数、分类缓存)

3.2 后端分层与模块化

模块	职责	本轮主要变更
user	注册、登录、资料、改密、头像	登录锁定与密码策略接入、会话时效由设置驱动、字段清空语义修正
product	商品发布/编辑/上下架/搜索/附近/评论	重新上架与彻底删除、编辑状态校验、事务补齐、评论购买校验、搜索多字段、估价开关
order / cart	下单锁定、订单状态机、购物车与收藏互转	支付与确认收货条件更新、超时自动取消、卖家可见订单详情
message	系统消息收件箱、私信与商品咨询	收件箱分页化、群发批次号、批量插入
admin	管理后台各页接口	扩展订单/评论/举报/趋势接口；删除商品复用商品模块级联逻辑
report (新增)	举报提交与处理	全新模块：实体/Mapper/服务/控制器
task (新增)	定时维护	超时订单取消、商品到期自动下架
config / utils	缓存、序列化、JWT、文件存储、请求上下文	缓存管理器显式化、序列化白名单、魔数校验、UserHolder 扩展

3.3 数据模型

数据库共 12 张表 (本轮新增 report 与 system_setting, 扩展 system_message 的 batch_no 列), 围绕「用户-商品-交易-消息」四条主线组织:

表	职责	关键设计
user	账号	BCrypt 密文; role 区分管理员; status 支持禁用
category / product / product_image	分类与商品	商品状态机 1 在售 / 2 已售出 / 3 已下架; 图片表首图冗余为封面
user_product_relation	收藏与购物车	同表以 relation_type 区分, 唯一索引防重, 互转零成本
product_order / order_item	交易	明细保存下单快照 (标题/封面/价格), 商品后续变更不影响历史订单
comment	评价	status 隐藏位预留; 评分与内容由 DTO 校验
private_message	私信与咨询	会话键由双方用户 ID 排序拼接加商品 ID 构成, 天然隔离越权

表	职责	关键设计
system_message	系统通知	receiver_type 群发标记 + batch_no 批次号（本轮新增）
report（新增）	举报	target_type + target_id 多态指向商品或评论，处理动作与备注留痕
system_setting（新增）	系统设置	单行表整体 JSON 覆盖；读取失败回落默认值

3.4 统一契约层

- 统一返回：所有接口返回 Result{code,msg,data}，业务码集中定义于 ResultCodeEnum，各模块不得自定义魔法值；
- 统一异常：业务错误抛 BusinessException，全局处理器兜底为固定文案，堆栈仅写入日志不外泄；
- 统一校验：入参 DTO 以 JSR-303 注解声明约束（@Pattern/@Size/@NotNull），控制器启用 @Validated，服务层只负责跨字段与状态类校验；
- 统一填充：create_time/update_time 由 MyMetaObjectHandler 自动填充，业务代码不再手工赋值。

3.5 鉴权与安全链路

本轮将「登录态解析」与「账号状态校验」合并进同一条拦截器链，消除了「禁用用户在 Token 有效期内仍可交易」的窗口期，同时使管理端角色校验不再额外查库：

请求 → JwtInterceptor

- └─ 解析 JWT（签名与过期校验；公开路径按「可选鉴权」处理）
- └─ getAuthUser(userId)：优先读 Redis user:info:{id}，未命中回源 MySQL 并重建缓存（密码不落缓存）
- └─ 账号不存在或 status=禁用 → 直接写 401 响应（禁用即时失效）
- └─ 通过 → UserHolder 写入 userId 与 User 实体（请求级复用）

→ AdminAuthInterceptor（仅 /admin/**）：复用 UserHolder 中的实体校验 role=1，不再查库

→ 业务 Controller：只承载业务规则，权限判断不侵入业务代码

3.6 并发与一致性设计

场景	机制	效果
下单锁商品	UPDATE product SET status=2 WHERE id=? AND status=1 条件更新，影响行数为 0 即整体回滚	同一件商品不会被两个买家同时购得
支付 / 确认收货	同款条件更新（WHERE status=期望值），失败提示刷新重试	并发下订单状态不会重复推进或跳状态
超时未支付	定时任务逐单条件更新取消并释放商品，与买家手动取消互不冲突	30 分钟未支付的订单确定性回收

场景	机制	效果
系统设置	落库 system_setting 单行表，保存即整体覆盖；读取失败回落默认值	设置真实约束业务（上传/限价/锁定/时效），且 Redis 重启不丢失
分类缓存	@Cacheable 写 Redis（TTL 10 分钟），管理端增删改时整组驱逐	高频下拉查询不落库，变更即时可见
上传安全	扩展名白名单（后台可配）+ 文件头魔数校验 + UUID 落盘	伪装成图片的可执行内容被拒绝

3.7 前端架构

前端按「布局 - 视图 - 共享组件 - 基础设施」四层组织：三个布局（MainLayout/AuthLayout/AdminLayout）承载导航与角标；视图按路由模块懒加载；本轮新增的共享组件 ProductCard 与 ApplImage 消除了商品卡片在两处页面重复实现、图片坏链无兜底两类问题。

- 状态管理：Pinia user store 是唯一状态中心（登录态归一化、未读私信/通知/购物车三个角标），Token 的持久化读写收敛在 utils/auth；
- 请求层：axios 拦截器统一注入 Token、解包 Result、401 清态跳登录、业务错误统一提示，页面 catch 中不再重复弹错；
- 契约对齐：utils/constants.js 集中维护与后端一致的枚举映射（订单 1~4、商品 1~3），本轮修正了过时的「7 状态」订单枚举并新增状态映射表供各页复用；
- 移动端：前台顶栏与后台侧边栏补齐汉堡菜单，私信中心双栏在窄屏改为上下堆叠。

「待补充：关键页面截图（首页、商品详情、管理看板），便于读者对照理解。」

3.8 对 AI 生成代码的约束手段

架构约束的本质是压缩新代码的自由发挥空间。本项目把约束分为四层，强度递增：

层级	手段	实例
结构约束	沿用既有域分包与分层命名，新模块复用成熟模块的骨架（report 模块完全参照 message 模块结构）	新增 report、task 两个包时无架构分歧
契约约束	枚举集中定义、DTO 校验注解、接口注释与 Swagger 注解齐全、Result 统一返回	全部新接口自动纳入拦截器保护，无一例外
流程约束	编辑前必读文件全文；每阶段编译；关键判断以对照实验取证	约 900 行的服务类先通读再修改，避免盲改
验证约束	冒烟测试将「设置真实生效」「评论需购买」等新契约固化为断言，回归不通过不得交付	336 项断言即架构的行为规范

一个典型的纠偏案例：扩展管理端时，模型曾生成一组引用已删除字段的包装方法；发现后没有叠加补丁，而是恢复必要的 Mapper 注入并将该段整体重写为直接调用。约束体系的价值不在于杜绝错误，而在于让错误被结构化的流程快速捕获并纠正。

第四章 可复现性论证

4.1 复现性声明

在满足 README 所列环境要求 (JDK 8+、Node 18+、MySQL 8、Redis 7) 的前提下，任何第三方从仓库零起步，可在 10 分钟内完成系统复现，并以单元测试 66 项、冒烟测试 336 项断言全部通过验证行为一致。复现性依赖以下四项机制：环境即代码、配置有默认值且可覆盖、行为有自动化断言、无外部付费服务依赖。

4.2 环境与依赖锁定

- 后端依赖由 pom.xml 锁定 (Spring Boot 2.7.12 parent 统一管理传递依赖版本)，构建产物为 second-hand-market-1.0.0.jar；
- 前端依赖由 package.json 与 package-lock.json 双重锁定，npm install 结果跨机器一致；
- 运行时要求宽松 (JDK 8+ 即可编译)，仓库 .tools/ 目录附带本机专用 Maven 3.9.16，消除工具链差异；
- 仅有的外部依赖是本地部署的 MySQL 与 Redis，不依赖任何云服务或付费接口。

4.3 数据与配置即代码

- 建库即重建：backend/scripts/01-schema.sql 单脚本创建全部 12 张表并写入种子数据 (3 个账号、2 件在售商品、8 个分类)，无手工步骤；
- 增量升级可重放：存量库执行 02-upgrade.sql 一次完成本轮表结构演进 (report、system_setting、batch_no)；
- 配置零改动可运行：application.yml 全部环境相关项写成 \${VAR:默认值} 形式，默认值即本地开发可用值，部署时以环境变量覆盖 (完整清单见附录 A)；
- 一键脚本：scripts/ 目录提供依赖拉起、建库、后端重建、一键启动四个批处理脚本，复现流程不依赖操作者记忆。

4.4 行为可验证：把复现从「能跑起来」变为「断言全绿」

复现成功的判定不依赖人工浏览页面，而以两组自动化套件为准：tests/api_smoke_test.py 覆盖 336 项断言 (健康检查、鉴权拦截、管理端全部页面、注册、发布、搜索、上传、评价、私信、购物车、订单全生命周期、举报闭环、数据导出与设置生效)；mvn test 提供 66 项单元测试 (商品服务与 AI 估价服务的边界条件)。两组套件均可在 1~2 分钟内完成，任何契约回归都会在分钟级暴露。

冒烟覆盖域	断言内容举例
鉴权与权限	未登录 401、普通用户访问后台 403、无关第三方查看订单 403
交易主链路	下单锁定商品、重复支付被拒、取消释放商品、确认收货状态机、订单快照不随商品删除失效

冒烟覆盖域	断言内容举例
设置真实生效	上传类型白名单拒绝 png、价格上限拒绝超限商品、会话超时写入 Token
评价新契约	未购买用户评价被拒、购买后可评、评论携带「已验证购买」标识
举报闭环	提交举报、重复举报被拒、管理端按举报下架商品、卖家重新上架
管理端	订单列表/详情/筛选、评论列表、看板趋势与分类分布、CSV 导出

「待补充：压力测试基准数据：可使用仓库自带的 tests/stress_test.js 采集吞吐量与 P95 延迟后填入本节，作为性能维度的复现指标。」

4.5 已知非确定性因素与影响分析

因素	来源	影响范围	控制手段
AI 估价随机波动	估价规则含 ± 200 元扰动，模拟 AI 不确定性	仅估价建议数值，不影响发布	单元测试断言区间而非精确值
时间戳	create_time、支付时间等取运行时刻	展示与排序，不影响业务	测试断言不比较绝对时间
并发购买结果	两人同时购买同一件商品，胜者取决于竞争顺序	订单归属的不确定性	条件更新保证「恰好一人成功」这一确定性
登录锁定计数	失败次数存 Redis，重置环境即清零	锁定时长内的登录尝试	冒烟测试不依赖锁定状态

4.6 复现演练记录

本轮升级完成后执行过一次完整演练，过程与结果如下，可作为复现指南的实测基线：

步骤	内容	结果
环境	Windows 11 / JDK 22 / Node 22 / MySQL 8 / Redis 7（本机服务）	就绪
建库	对既有库执行 02-upgrade.sql，确认 12 张表与 batch_no 列	通过
构建	mvn -DskipTests package 生成 jar；前端 npm run build 通过并完成分包	通过
启动	java -jar 启动后端，/api/health 返回 code=200	通过
单元测试	mvn test: Tests run 66, Failures 0, Errors 0	通过
冒烟测试	python tests/api_smoke_test.py: 通过 336，失败 0	通过
行为抽检	登录 Token 有效期随「会话超时」设置变为 12 小时，验证设置真实生效	通过

第五章 总结与展望

本轮升级验证了一条可复用的 AI 辅助改造路径：以结构化盘点建立共同事实，以经人工审查的编号清单锚定意图，以分阶段验证闸门控制风险，最终以自动化断言交付可复现的结果。56 项清单中 52 项落地，4 项按审查约定延后并记录了理由；两套测试从部分失真恢复到全绿；安全工具与测试套件在过程中各自拦截了真实问题，说明「约束 + 验证」的组合比「生成后人工审读」更可靠。

后续路线建议按三个方向推进：其一，接入真实支付网关与 WebSocket 推送（本轮明确延后的两项，接口形状已为其预留）；其二，将冒烟测试纳入 CI，在每次提交时自动执行；其三，补齐本轮标注为「待补充」的项目背景、界面截图与压测基准数据，使文档自治程度进一步提升。

附录 A 环境变量表

变量	默认值	说明	部署必改
DB_HOST / DB_PORT	localhost / 3306	MySQL 地址	—
DB_NAME	secondhand_market	库名，与建表脚本一致	—
DB_USERNAME / DB_PASSWORD	root / 1234	数据库凭据	密码必改
REDIS_HOST / REDIS_PORT	localhost / 6379	Redis 地址	—
JWT_SECRET	内置默认串	HS256 签名密钥，不少于 32 字节	必改
JWT_EXPIRATION	604800000	Token 默认有效期（毫秒），后台安全设置可覆盖	—
FILE_UPLOAD_DIR	./uploads	上传落盘目录	建议挂独立数据卷

附录 B 接口清单摘要

模块	代表性端点	权限
user	POST /user/register · POST /user/login · GET/PUT /user/info · PUT /user/password · POST /user/avatar	注册登录免鉴权，其余需登录
product	POST /product/add · GET /product/search · GET /product/detail/{id} · POST /product/nearby · POST /product/estimate · PUT/DELETE /product/{id} · POST /product/{id}/reshelf · DELETE /product/{id}/purge · GET/POST /product/{id}/comments · POST /product/upload	搜索/详情/分类/评论读公开，其余需登录
report (新增)	POST /report	需登录
order	POST /order/create · GET /order/list · GET /order/sold · GET /order/{orderNo} · POST /order/{orderNo}/pay cancel confirm	需登录

模块	代表性端点	权限
cart	POST/DELETE /cart/{productId} · GET /cart/list · GET /cart/count · 购物车收藏互转	需登录
message	GET /message/list · POST /message/{id}/read · POST /message/all/read · GET /message/unread/count · POST /message/private/send · GET /message/private/chat · GET /message/private/conversations	需登录
admin	GET /admin/dashboard · /admin/stats/trend · /admin/stats/category · /admin/orders · /admin/comments · /admin/reports · /admin/users · /admin/products · /admin/categories · /admin/messages · GET/PUT /admin/settings · POST /admin/upload · /admin/export/*	需管理员
public (新增)	GET /public/settings	免鉴权

附录 C 常见问题

- 接口统一返回 code=501「系统内部错误」：MySQL 或 Redis 未启动。运行 scripts/start-dev-services.bat 后无需重启后端，应用会自动重连；
- 报 Table secondhand_market.user doesn't exist：库未初始化，执行 scripts/init-database.bat 或手动导入 backend/scripts/01-schema.sql；
- 老库启动报 Unknown column batch_no：执行一次 backend/scripts/02-upgrade.sql；
- 注册报「密码强度不足」：后台安全设置默认 medium（须同时包含字母与数字），演示可临时调为 low；
- 发布商品报「超过平台上限」：后台交易设置的价格上限真实生效，按需调整；
- 图片上传失败：确认上传目录可写、文件为真实图片（服务端校验文件头），且单张不超过后台设置的大小上限。